MODULE 16 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Least Privilege and Cross-Account Access

Grant only what is used, prove it with Access Analyzer, and cross account boundaries without opening doors you did not mean to.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 16 of 52

admin@sthithapragna.com

Least privilege is a **loop**, not a document. Grant, observe, refine, and guard the next change.

Who has to say yes?

REQUEST	POLICIES THAT MUST ALLOW
Same account	Identity policy or resource policy
Cross-account, resource policy	Both: caller's identity policy and the resource policy
Cross-account, assume role	Caller may AssumeRole, and the role trusts the caller
Any request	No explicit deny, and SCPs, RCPs and boundaries allow

ON THE EXAM

Within one account, either side can grant. Across accounts, both sides must grant.

Assume a role, or use a resource policy?

ASSUME A ROLE

Become a principal there

- Works for every service
- Gives up the caller's own permissions
- Trust policy controls who may enter
- Session is logged in the target account

RESOURCE-BASED POLICY

Reach in as yourself

- S3, KMS, SQS, SNS, Lambda and others
- Keeps the caller's own permissions
- Needed to copy between two accounts
- Resource owner names allowed principals

THE TIEBREAKER

Moving data between your resource and theirs in one call needs a resource policy, because a role swaps permissions.

Organisation-aware conditions

- **aws:PrincipalOrgID** in a resource policy: any principal in my organisation.
- **aws:PrincipalOrgPaths**: only principals under a given OU.
- **aws:ResourceOrgID** in an identity policy: only resources in my organisation.
- **aws:SourceOrgID**: for AWS service principals acting for my organisation.
- New accounts are covered automatically; no account ID lists to maintain.

> ON THE EXAM
>
> Listing account IDs in a policy is the distractor. An organisation condition is the scalable answer.

Which confused deputy defence?

THIRD PARTY ASSUMES YOUR ROLE

sts:ExternalId

- Vendor's account is the principal
- Unique ID per customer, set by vendor
- Condition in the role's trust policy
- Stops one customer naming another's role

AWS SERVICE ACTS ON YOUR BEHALF

aws:SourceArn and SourceAccount

- Service principal such as sns.amazonaws.com
- Condition in the resource policy
- Pins the exact bucket, topic or rule
- Stops another account's resource using it

THE TIEBREAKER

ExternalId is for a vendor assuming a role. SourceArn and SourceAccount are for AWS service principals.

IAM Access Analyzer, three analysers

ANALYSER	ANSWERS	COST
External access	What is shared outside my zone of trust?	Free
Internal access	Which of my principals can reach this resource?	Per monitored resource
Unused access	Which roles, keys and permissions go unused?	Per role or user

ON THE EXAM

Set the zone of trust to the organisation, so sharing between member accounts is not reported as external.

Closing the least-privilege loop

TOOL	WHEN IT ACTS	WHAT IT DOES
Policy generation	After activity	Drafts a policy from CloudTrail usage
Unused access findings	Continuously	Recommends permissions to remove
Policy validation	While authoring	Flags errors and security warnings
Custom policy checks	In the pipeline	Blocks new access, public access, named actions

ON THE EXAM

Stop a bad policy before deployment with custom policy checks. Find drift afterwards with analyser findings.

Delegating administration safely

PERMISSIONS BOUNDARY

A ceiling on a principal

- Attached to a role or user
- Effective access is the intersection
- Grants nothing by itself
- Lets developers create roles safely

SCPS AND RCPS

A ceiling on accounts

- Attached to the organisation, OU or account
- Apply to every principal or resource
- Grant nothing by itself
- Management account is not affected

THE TIEBREAKER

Let teams create their own roles, but require a boundary on every role they create.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Vendor assumes a role in many customers' accounts	sts:ExternalId
Service principal writes to your topic or bucket	aws:SourceArn, aws:SourceAccount
Share with every account, including future ones	aws:PrincipalOrgID
Developers create roles without escalation	Required permissions boundary
Permissions granted but never used	Unused access analyser
Block risky policies before deployment	Custom policy checks

ON THE EXAM

Detective findings explain what is wrong now. Preventive checks stop the next change.

> A monitoring vendor needs read access to Meridian Freight's AWS accounts. The vendor's platform assumes a role in each customer's account from its own AWS account.
>
> Meridian's security team is worried that another vendor customer could configure the platform to read Meridian's data.

What should the solutions architect add to the role?

A An aws:SourceArn condition naming the vendor's platform

B An aws:PrincipalOrgID condition for Meridian's organisation

C IAM user access keys issued to the vendor instead of a role

D An sts:ExternalId condition in the trust policy, using the unique ID the vendor assigned to Meridian

◆ PAUSE AND DECIDE

What should the solutions architect add to the role?

A aws:SourceArn

For AWS service principals, not a vendor's own account assuming a role.

B aws:PrincipalOrgID

The vendor is outside Meridian's organisation, so this would lock it out.

C IAM user keys

Long-lived secrets, and no protection against the confused deputy.

D sts:ExternalId

The platform only assumes the role when acting for the customer holding that ID.

THE SIGNAL

A third party assuming roles across many customers is the textbook case for an external ID.

> Meridian Freight wants application teams to create IAM roles for their own Lambda functions without waiting for the central security team.
>
> Teams must not be able to create a role with more permissions than an approved set, or remove that limit later.

What should the solutions architect implement?

A. Allow iam:CreateRole only when the iam:PermissionsBoundary condition names an approved boundary, and deny changing or deleting boundaries

B. An SCP that denies iam:CreateRole in all application accounts

C. AdministratorAccess for team leads, with CloudTrail alerts on IAM changes

D. A weekly review of new roles by the security team

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Required boundary

Self-service role creation, capped by the boundary, which teams cannot remove.

B SCP deny

Removes self-service entirely, failing the first requirement.

C Admin plus alerts

Detects escalation after it happens rather than preventing it.

D Weekly review

A week of exposure, and still a manual gate.

THE SIGNAL

Delegate role creation, require the boundary, protect the boundary.

> Meridian Freight has 180 accounts in AWS Organizations. An audit found many roles with broad permissions copied from templates years ago.
>
> The security team wants an ongoing, organisation-wide view of unused roles and unused permissions, with suggested policy changes.

What should the solutions architect recommend?

A Generate a policy from CloudTrail for each role, one role at a time

B Download the IAM credential report from each account monthly

C An AWS Config rule that flags roles with AdministratorAccess

D An unused access analyser with the organisation as its zone of trust, using its recommendations to remove permissions

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Per-role policy generation

Useful for one role; not an ongoing view across 180 accounts.

B Credential report

Covers users and keys only, per account, with no permission detail.

C Config rule

Finds one named policy, not permissions that go unused.

D Organisation unused access analyser

Continuous findings for every role, with removal recommendations.

THE SIGNAL

Ongoing, organisation-wide, unused, with recommendations. Every word points to the unused access analyser.

> A central S3 bucket holds Meridian Freight's shared reference data. Every account in the organisation must be able to read it, including accounts created in future.
>
> The platform team does not want to edit the bucket policy whenever an account is added.

What should the bucket policy use?

A. Allow s3:GetObject to any principal, with an aws:PrincipalOrgID condition matching the organisation ID

B. A list of every member account ID as principals

C. Share the bucket with the organisation through AWS RAM

D. Make the bucket public and restrict it with an S3 gateway endpoint

◆ PAUSE AND DECIDE

What should the bucket policy use?

A aws:PrincipalOrgID

Every current and future account in the organisation, no edits.

B List of account IDs

Works today; needs an edit for every new account.

C AWS RAM

RAM does not share S3 buckets; access is by bucket policy.

D Public bucket

Public access, which Block Public Access should prevent anyway.

THE SIGNAL

Future accounts, no edits. That is an organisation condition, not a list.

> Meridian Freight deploys IAM and resource policies through a CI/CD pipeline. A recent change made a bucket public, and another granted s3:DeleteBucket to an application role.
>
> The team wants the pipeline to fail such changes before they are deployed.

What should the solutions architect add to the pipeline?

A. An external access analyser that alerts on new public findings

B. An SCP denying s3:DeleteBucket across the organisation

C. IAM Access Analyzer custom policy checks, using CheckNoPublicAccess and CheckAccessNotGranted for the listed actions

D. A template linter that checks policy syntax

◆ PAUSE AND DECIDE

What should the solutions architect add to the pipeline?

A External access analyser

Detective: reports after the bucket is already public.

B SCP deny

Blocks one action everywhere, not public access, and not a pipeline gate.

C Custom policy checks

Fails the build on public access or on the named actions.

D Syntax linter

Valid syntax can still grant dangerous access.

THE SIGNAL

Before deployment means preventive. Analyser findings arrive after deployment.

> An S3 bucket in Meridian Freight's account sends event notifications to an SNS topic. The topic policy currently allows the s3.amazonaws.com service principal to publish.
>
> The security team wants only that one bucket, in Meridian's own account, to be able to publish through S3.

What should the solutions architect add to the topic policy?

A aws:SourceArn matching the bucket ARN and aws:SourceAccount matching Meridian's account

B An sts:ExternalId condition

C An aws:PrincipalOrgID condition for Meridian's organisation

D Replace the service principal with Meridian's account root

◆ PAUSE AND DECIDE

What should the solutions architect add to the topic policy?

A SourceArn and SourceAccount

Pins the service's actions to Meridian's own bucket.

B ExternalId

For third parties assuming a role, not service principals.

C PrincipalOrgID

A service principal is not in your organisation, so this blocks the bucket.

D Account root

The publisher is the S3 service, which would then be denied.

THE SIGNAL

Service principal acting for a resource: pin the source. Vendor assuming a role: external ID.

What to carry out of this module

- **Across accounts both sides must allow.** Within one account either side can.
- **ExternalId** for vendors assuming roles; **SourceArn** for service principals.
- **Organisation conditions** replace account ID lists and cover future accounts.
- **Unused access findings** refine; **custom policy checks** prevent.
- **Delegate with a required boundary**, and deny removing it.

> ON THE EXAM
>
> Least privilege is grant, observe, refine, and guard the next change.